

TimeFit Toss Place API 연동 문서

운영 및 개발 참조 문서

작성일: 2026-09-16

대상 저장소: sh414lim/time-fit

기준: 현재 저장소 구현. 인증 카·시크릿의 실제 값은 의도적으로 기록하지 않는다.

1. 연동 범위

TimeFit은 Toss Place 주문을 읽기 전용으로 수집하고, Supabase에 원본 주문과 일별 집계를 저장한 뒤 매출·메뉴·손익 화면에서 사용한다. TimeFit에서 Toss 주문, 결제, 취소 상태를 변경하는 API는 호출하지 않는다.

```
Toss Place Open API
-> POST /api/sync-sales
-> tossplace_orders ( upsert)
-> timefit_user_refresh_tossplace_daily_sales RPC
-> timefit_user_tossplace_daily_sales ( )
-> GET /api/organization-sales-dashboard
-> /
```

외부 Toss 개발자센터: <https://developers.tossplace.com/plugins/878>

2. 외부 Toss Place Open API

주문 목록 조회

항목	값
Method	GET
Base URL	https://open-api.tossplace.com/api-public/openapi/v1
Path	/merchants/{merchantId}/order/orders
인증 헤더	x-access-key, x-secret-key
Query	page, size, sortOrder=DESC, 선택적으로 from, to
용도	주문 원본, 상태, 금액, 완료·취소 시각과 메뉴 항목 수집

기간 값은 KST 날짜 경계를 UTC ISO 문자열로 변환한다.

```
2026-08-01 -> 2026-07-31T15:00:00.000Z
2026-08-31 -> 2026-08-31T14:59:59.999Z
```

- 수동 기간 동기화는 최대 1년이다.
- 기간 조회는 페이지당 최대 500건, 최대 20페이지까지 수집한다.
- 상한에 도달하면 불완전한 수집을 성공으로 처리하지 않고 오류를 반환한다.
- `order.id`가 없는 항목은 저장하지 않는다.

주문 필드 매핑

Toss 응답 후보	TimeFit <i>tossplace_orders</i>	처리
id	order_id	문자열 변환
orderKey	order_key	없으면 null
orderState 또는 state	state	원본 상태 유지
source	source	주문 유입 경로
createdAt 또는 orderedAt	ordered_at	유효한 날짜만 저장
completedAt	completed_at	완료 매출 판정에 사용
cancelledAt	cancelled_at	취소 집계에 사용
chargePrice.totalAmount 등	total_amount	숫자 변환, 실패 시 0
주문 전체 객체	raw_order	매뉴 분석을 위한 원본 JSON

동일 merchant_id + order_id는 upsert하므로 같은 기간을 다시 동기화해도 주문 행이 중복 생성되지 않는다.

3. TimeFit 서버 API

모든 경로는 Vercel 통합 라우터 `api/[...route].js`를 거친다.

POST /api/sync-sales

사업장 한 곳의 수동 동기화 또는 Vercel Cron의 전체 사업장 자동 동기화 API다.

사용자 호출

```
POST /api/sync-sales
Authorization: Bearer <Supabase user access token>
Content-Type: application/json

{
  "organizationId": "<uuid>",
  "mode": "range",
  "from": "2026-08-01",
  "to": "2026-08-31"
}
```

- `sales.sync` 권한이 필요하다.
- 클라이언트가 `organizationId`를 전송해야 한다.
- `mode`: `daily`, `range`, `backfill`. 명시되지 않거나 알 수 없는 값이면 `daily`다.
- `from`, `to`는 둘 다 YYYY-MM-DD여야 한다.

Cron 호출

```
GET /api/sync-sales
Authorization: Bearer <CRON_SECRET>
```

`vercel.json` 기준 매일 0 13 * * *(UTC), 즉 KST 22:00에 실행된다. `daily` 범위는 전일 00:00 KST부터 실행 시각과 당일 22:00 KST 중 빠른 시각까지다.

성공 응답

```
{
  "ok": true,
  "mode": "range",
}
```

```

"page": 1,
"synchronized": 1702,
"stores": 1,
"results": [
  { "organizationId": "<uuid>", "synchronized": 1702 }
]
}

```

stores: 0은 서버 요청 자체는 성공했지만 활성화된 유효 연결이 없었다는 뜻이다. 주문 수집 성공과 동일하게 해석하면 안 된다.

대표 오류

HTTP	code/메시지	의미
401	관리자 인증 필요	사용자 토큰·Cron 인증 실패 또는 권한 없음
422	toss_auth_failed	Toss Access Key·Secret 또는 POS 연결 확인 필요
502	toss_sync_failed	권한, 판매점 ID, Toss/Supabase 처리 실패 등
503	Missing server configuration	Supabase 서버 환경변수 누락

실패 시 연결의 `connection_status`, `last_error`와 동기화 상태의 `last_sync_error`를 갱신한다. 성공 시 일별 캐시를 다시 계산하고 `last_synced_at`과 성공 범위를 저장한다.

GET /api/organization-sales-dashboard

TimeFit 로그인 사용자의 사업장별 매출 화면 API다.

```

GET /api/organization-sales-dashboard?organizationId=<uuid>&from=2026-08-01&to=2026-08-31
Authorization: Bearer <Supabase user access token>

```

- `sales.view` 또는 `sales.sync` 권한이 필요하다.
- 사업장별 RPC `timefit_user_sales_dashboard` 결과를 반환한다.
- 완료 매출, 전체/완료/취소 주문, 메뉴별 판매, 최근 주문과 연결 상태가 포함된다.
- 응답은 사용자 전용으로 `private`, `max-age=30`, `stale-while-revalidate=300` 캐시 정책을 사용한다.
- 브라우저는 사업장+기간별 결과를 메모리와 `sessionStorage`에 3분간 저장해 탭 재진입 시 전체 로딩을 줄인다.

POST /api/tossplace-bootstrap-connection

서버 공용 Toss 계정을 현재 사업장에 연결한다.

```

{
  "organizationId": "<uuid>",
  "displayName": "Toss Place",
  "serviceId": "<service-id>",
  "serviceCode": "<service-code>"
}

```

- Supabase 사용자 토큰과 해당 사업장의 `manager` 멤버십이 필요하다.
- `merchant_id`는 서버 환경변수 `TOSSPLACE_MERCHANT_ID`에서 가져온다.
- `credential_source`는 `platform`으로 저장되고 개별 암호문은 비운다.

POST /api/tossplace-custom-credentials

사업장 전용 Access Key·Secret을 저장한다.

```

{
  "organizationId": "<uuid>",

```

```

"accessKey": "<secret>",
"accessSecret": "<secret>"
}

```

- Supabase 사용자 토큰과 해당 사업장의 **manager** 멤버십이 필요하다.
- **INTEGRATION_ENCRYPTION_KEY**를 이용한 AES-256-GCM으로 서버에서 암호화한다.
- DB에는 **encrypted_access_key**, **encrypted_access_secret**만 저장한다.
- 저장 후 원문을 다시 반환하거나 UI에 재표시하지 않는다.
- 새 값을 입력해 교체하는 방식만 지원한다.

GET/POST /api/tossplace

Toss Place 웹훅 수신 경로다.

- GET: 상태 확인용 { "ok": true, "service": "timefit-tossplace-webhook" }.
- POST: 이벤트 유형, 판매점/주문/결제 ID만 최소 로그로 남기고 200을 반환한다.
- 고객 정보가 포함될 수 있어 전체 payload는 로그로 남기지 않는다.
- 현재 구현은 웹훅 서명 검증, 재전송 방지, 주문 저장을 하지 않는다. 실시간 반영의 신뢰 경로로 사용하기 전에 반드시 보완해야 한다.

레거시 Basic Auth 조회 API

API	용도	인증
GET /api/sales-dashboard	공용 판매점 주문 요약·최근 주문	DASHBOARD_USERNAME/PASSWORD Basic Auth
GET /api/menu-sales-dashboard	공용 판매점 메뉴 매출 요약	동일

두 API는 **TOSSPLACE_MERCHANT_ID** 한 곳을 대상으로 한다. 신규 TimeFit 관리자 화면은 사업장 권한을 검사하는 **/api/organization-sales-dashboard**를 사용한다.

4. 연결 정보와 비밀정보

비밀이 아닌 사업장 연결 정보

timefit_user_tossplace_connections에 다음 값을 저장한다.

- **organization_id**, **display_name**
- **service_id**, **service_code**
- **merchant_id**
- **sync_enabled**, **connection_status**
- **credential_source**: platform 또는 custom
- **last_synced_at**, **last_error**

service_id/service_code는 POS의 코드 연결 정보이고 **merchant_id**는 Open API 주문 조회용 숫자 판매점 ID다. 서로 대체할 수 없다.

서버 환경변수

이름	목적	노출 금지
TOSSPLACE_ACCESS_KEY	플랫폼 공용 API 키	Git, 브라우저, 로그
TOSSPLACE_ACCESS_SECRET	플랫폼 공용 API 시크릿	Git, 브라우저, 로그
TOSSPLACE_MERCHANT_ID	공용 판매점 기본값/레거시 조회	공개 문서에는 실제 운영값 지양
INTEGRATION_ENCRYPTION_KEY	사업장 전용 키 암호화용 32-byte base64 키	Git, DB 평문, 로그
CRON_SECRET	자동 동기화 인증	Git, 클라이언트
SUPABASE_URL	서버 DB API 주소	서버 환경에서 관리
SUPABASE_SERVICE_ROLE_KEY	RLS 우회 서버 키	절대 클라이언트 노출 금지
DASHBOARD_USERNAME/PASSWORD	레거시 매출 화면 Basic Auth	Git, 로그

운영 키가 채팅, 화면 캡처 또는 커밋에 노출되었다면 문서에 옮기지 말고 Toss 개발자센터에서 폐기·재발급한다.

5. 저장·집계 데이터

저장소	역할
tossplace_orders	Toss 주문 원본과 raw_order 저장, merchant_id + order_id 중복 방지
tossplace_sync_state	시작/성공 시각, 성공 범위, 최근 오류 기록
timefit_user_tossplace_daily_sales	조직·판매점·영업일별 완료 매출과 주문 수 캐시
timefit_user_tossplace_connections	조직별 연결, 상태, 인증정보 출처

일별 집계는 한국 시간 기준 `completed_at` 날짜로 생성한다. 화면 조회 시 원본 주문을 매번 전부 합산하지 않고, 동기화 직후 갱신한 일별 캐시를 사용한다.

6. 운영 절차

최초 연결

1. Toss 개발자센터에서 주문 조회 권한이 있는 앱과 판매점을 확인한다.
2. TimeFit > Toss Place 에 서비스 ID, 서비스 코드, 판매점 ID를 저장한다.
3. 플랫폼 공용 키를 쓸지 사업장 전용 키를 쓸지 선택한다.
4. 짧은 기간으로 수동 동기화한다.
5. `stores > 0, synchronized`, 연결 상태와 마지막 동기화 시각을 확인한다.
6. Toss 원천의 완료·취소 주문 수/금액과 TimeFit 매출 분석을 대조한다.

과거 데이터 백필

7. 한 번에 1년 이하의 기간을 선택한다.
8. 월 단위 또는 더 짧은 범위로 `mode=range` 동기화한다.
9. 동일 기간을 한 번 더 실행해 주문 수와 금액이 증가하지 않는지 확인한다.

10. `tossplace_orders`와 일별 캐시, 매출 분석, 손익 화면의 기간 합계를 비교한다.

키 교체

11. 새 키에 대상 판매점 주문 조회 권한이 있는지 확인한다.
12. Vercel 환경변수 또는 TimeFit 맞춤 인증정보를 교체한다.
13. 이전 키를 Toss 개발자센터에서 폐기한다.
14. 짧은 기간 동기화 후 401/403이 없는지 확인한다.
15. 전체 기간을 재수집하지 말고 필요한 누락 범위만 백필한다.

7. 장애 점검표

증상	우선 확인
<code>stores: 0</code> 인데 성공처럼 보임	연결의 <code>sync_enabled</code> , <code>merchant_id</code> , <code>organization_id</code>
401 / <code>toss_auth_failed</code>	Access Key-Secret 쌍, POS 서비스 코드 연결, 키 교체 여부
403	개발자 앱의 판매점 주문 조회 권한
404	숫자 <code>merchant_id</code> , Toss 주문 조회 경로
동기화했지만 화면이 과거 값	<code>last_synced_at</code> , 일별 캐시 RPC, 화면 강제 조회
월 경계 금액 불일치	KST 기준 <code>from/to</code> , <code>completed_at</code> 과 <code>ordered_at</code> 차이
중복 주문	(<code>merchant_id</code> , <code>order_id</code>) 유니크/업서트 상태
메뉴 수량이 없음	<code>raw_order</code> 에 메뉴 항목이 포함됐는지 확인

8. 보안 및 구현상 주의사항

- Access Secret을 Markdown, 이슈, 커밋, 클라이언트 환경변수(`VITE_*`)에 기록하지 않는다.
- 서버 로그에는 인증 헤더, 원문 키, 전체 웹훅 payload를 남기지 않는다.
- `SUPABASE_SERVICE_ROLE_KEY`를 쓰는 API는 사용자 토큰과 조직 권한을 먼저 검증해야 한다.
- 사업장 연결을 저장할 때 `merchant_id` 누락을 성공 연결로 표시하지 않는다.
- 자동/수동 동기화 응답에서 `stores: 0`을 운영 성공으로 집계하지 않는다.
- 웹훅을 활성 처리 경로로 전환하기 전에 서명 검증, timestamp 허용 범위, replay 방지, 조직 매핑과 먹등 저장을 구현한다.
- 현재 코드의 `server/api/organization-sales-dashboard.js`는 `authorizeFinance`를 사용하므로 배포 전 import/실행 테스트에서 권한 검사 모듈이 정상 연결되는지 확인한다.

9. 관련 코드

- `server/api/sync-sales.js`: Toss 주문 수집, 저장, 집계 갱신
- `server/api/tossplace.js`: 웹훅/상태 확인
- `server/api/tossplace-bootstrap-connection.js`: 플랫폼 연결 등록
- `server/api/tossplace-custom-credentials.js`: 사업장 전용 인증정보 암호화 저장

- `server/api/_integration-crypto.js`: AES-256-GCM 암호화
- `server/api/organization-sales-dashboard.js`: TimeFit 사업장 매출 조회
- `server/api/sales-dashboard.js`: 레거시 주문 요약 조회
- `server/api/menu-sales-dashboard.js`: 레거시 메뉴 매출 조회
- `src/lib/supabase.js`: 브라우저 API 호출과 3분 매출 캐시
- `supabase/migrations/20260827000100_tossplace_daily_sales_cache.sql`: 일별 캐시/RPC
- `vercel.json`: 매일 자동 동기화 스케줄